Báo Cáo Sprint 0 — Khảo Sát Và Chuẩn Bị

Đề tài: Ứng Dụng Phân Tích Kiểm Tra Bảo Mật Cho Các Hệ Thống Phần Mềm Website Bằng AI
Sinh viên: Đào Xuân Dương — MSSV: 235748010110040 **Thời gian sprint:** 20/10/2026 – 26/10/2026

1. Mục tiêu sprint

- Khảo sát các ứng dụng phân tích, kiểm tra bảo mật website hiện có
- Lựa chọn công nghệ xây dựng hệ thống
- Lập kế hoạch thực hiện toàn bộ đồ án theo sprint
- Tạo kho lưu trữ mã nguồn và tài liệu trên GitHub

2. Công việc đã thực hiện

2.1. Khảo sát các ứng dụng tương tự

Ứng dụng	Đặc điểm	Nhận xét
OWASP ZAP	Công cụ quét lỗ hổng web tự động, mã nguồn mở, miễn phí	Mạnh và phổ biến, nhưng giao diện phức tạp, kết quả khó đọc với người không chuyên
Burp Suite	Công cụ kiểm thử bảo mật chuyên nghiệp dạng proxy chặn request	Chuẩn nghề kiểm thử, bản đầy đủ có phí, thiên về kiểm tra thủ công
Snyk	Quét lỗ hổng trong mã nguồn và thư viện, có AI hỗ trợ sửa	Tập trung vào mã nguồn, không quét website đang chạy
Semgrep	Quét mã nguồn theo bộ quy tắc bảo mật, có trợ lý AI	Tương tự Snyk, hướng tới lập trình viên
XBOW	Hệ thống AI tự động đóng vai hacker kiểm thử website	Hướng đi mới bằng AI, là sản phẩm thương mại, không tự xây dựng được
Pentest-Tools.com	Nền tảng quét bảo mật trực tuyến	Tiện lợi nhưng bản miễn phí giới hạn, quét ở mức cơ bản

Kết luận khảo sát: Các công cụ hiện có hoặc phức tạp với người dùng phổ thông, hoặc chỉ quét mà phần giải thích kết quả còn nặng thuật ngữ. Đây là khoảng trống để đề tài hướng tới: kết hợp module quét tự động với AI phân tích, giải thích dễ hiểu và đề xuất khắc phục.

2.2. Lựa chọn công nghệ

Thành phần	Lựa chọn	Lý do
Ngôn ngữ	Python	Nhiều thư viện hỗ trợ xử lý web và gọi API AI
Framework web	Flask	Nhẹ, dễ học, phù hợp quy mô đồ án
Cơ sở dữ liệu	SQLite	Không cần cài thêm máy chủ CSDL
AI	OpenAI API (GPT)	Khả năng phân tích và diễn đạt tốt, dễ tích hợp
Giao diện	HTML/CSS/JS + Bootstrap	Nhanh, giao diện rõ ràng

2.3. Mô tả hệ thống dự kiến

Người dùng nhập URL website → hệ thống thu thập thông tin và chạy các module kiểm tra (SSL/HTTPS, security headers, nhận diện công nghệ, XSS, SQL Injection, lộ thông tin) → kết quả thô được gửi cho AI phân tích (phân loại theo OWASP Top 10, đánh giá mức độ nguy hiểm, giải thích, đề xuất khắc phục) → hệ thống hiển thị kết quả và xuất báo cáo, đồng thời lưu lại lịch sử các lần kiểm tra.

2.4. Lập kế hoạch và tạo kho GitHub

- Đã xây dựng kế hoạch 16 sprint (xem file `KE-HOACH-SPRINT.md`)
- Link kho GitHub: (điền sau khi tạo repo)

3. Kết quả đạt được

- Hoàn thành khảo sát và rút ra hướng đi của đề tài
- Chốt xong bộ công nghệ sử dụng
- Có bản mô tả hệ thống dự kiến và kế hoạch sprint chi tiết

4. Kế hoạch Sprint 1 (27/10 – 02/11/2026)

- Thiết kế cơ sở dữ liệu cho hệ thống
- Hoàn thiện sơ đồ kiến trúc
- Phác thảo giao diện các trang chính

5. Khó khăn

- Chưa phát sinh khó khăn lớn. Nội dung cần tìm hiểu thêm ở các sprint sau: cách gọi API AI và cách xây dựng module quét an toàn, không gây ảnh hưởng tới website được kiểm tra.